IBVS: End-to-End Audit and QA Report

Iraq Billboard Verification System · Repository hizendevelopers/OOH · Production: ooh-green.vercel.app
Audit date: 9 November 2026 · Branch audited: main (commit 4741b60, after PR #3) · Prepared by Claude Code for the project owner

1. Executive summary

The application's code is in good shape on the checks that can be run here: lint, types, 124 unit and integration tests, dependency vulnerabilities, and the browser flows all pass. Production blocks anonymous access, has the required security headers, and has sign-up turned off.

Four issues need action before real field use. The most serious is that **uploaded photos are stored on the server's disk**, but the live site is on Vercel, which does not keep files between deployments. The other three are the health check that reports the wrong migration, no multi-factor sign-in for supervisors, and no test on real phones. The database was also out of date until today, which caused the failed saves described in section 5; it is now up to date.

> **Overall verdict:** not ready for a pilot with real workers until the two Critical items in section 4 are closed and the phone test in section 6 passes.

Findings by severity

Severity	Count	Items
Critical	1	F-01 photo storage on a host that does not keep files
High	4	F-02 health check reports the wrong migration · F-03 no multi-factor sign-in for supervisors · F-04 no real-phone testing · F-05 workers' old two-photo drafts are rejected
Medium	4	F-06 Content Security Policy allows inline scripts · F-07 production PostGIS path not verified · F-08 database changes are a manual step, not part of deployment · F-09 new Arabic text not reviewed by a native speaker
Low	4	F-10 health endpoint publicly reveals database type · F-11 location-form test was timing-sensitive · F-12 duplicated fetch code in the review workspace · F-13 documentation claims ahead of evidence

2. Scope and method

- **Automated checks:** ESLint, TypeScript typecheck, Vitest unit and integration suite (embedded PostgreSQL), production build, Playwright browser acceptance on the production build, and `npm audit`.
- **Code review:** authentication and session settings, origin and CSRF checks on mutating routes, organization isolation in server queries, SQL construction, security headers, secret handling, evidence storage, and deployment assumptions in the repository documentation.
- **Live read-only checks:** anonymous responses from production endpoints, response security headers, and the health endpoint. No data was written to production.

- **Out of scope:** real Android and iPhone devices, camera and GPS on real hardware, load testing, penetration testing by an outside party, and a review of the Supabase project settings.

3. Results of automated checks

Check	Result	Notes
ESLint (`npm run lint`)	Pass	No errors or warnings.
TypeScript (`npm run typecheck`)	Pass	Covers the web app and the tests.
Unit and integration tests (Vitest)	Pass: 124 of 124, 20 files	Includes dimensions, advertiser history, angle-photo rules, offline sync, evidence integrity, review workflow and access control.
Dependency audit (`npm audit --omit=dev --audit-level=high`)	Pass: 0 vulnerabilities	Production dependencies only.
Production build (webpack)	Pass	The default Turbopack build failed on the audit machine with a Windows child-process error. It is not caused by application code (see F-14).
Browser acceptance (Playwright, production build)	Pass: 9 of 9	Nine flows: field capture, offline sync, GPS and storage failures, logout, locations, review, workers, sign-in and access rules.

3.1 Browser acceptance

All nine flows passed on the production build of current `main` (commit 4741b60). The run is on Chromium with simulated camera and GPS, so it does not replace the real-phone test in F-04.

4. Findings

Each finding lists the evidence, the risk, and the recommended fix. Severity reflects the risk to workers and to the integrity of evidence.

F-01 · Critical · Uploaded photos depend on a server disk that the live host does not keep

Evidence: `apps/web/src/server/evidence-storage.ts` writes every photo under `IBVS_EVIDENCE_DIR` and refuses to run in production without a private, persistent directory. The architecture document (`docs/ARCHITECTURE.md`) says the design is for a single persistent host and "does not support ephemeral/serverless disks". The live site is served from Vercel, and the repository has no configuration that provides a persistent volume.

Risk: photos may fail to save, or may disappear when the host restarts or redeploys. Evidence is the core of the product, so this is a data-loss risk.

Fix: choose one, in this order of preference:

1. Host the application on a server with a persistent disk, using the Docker setup in `docs/DEPLOYMENT.md`, and point `IBVS_EVIDENCE_DIR` at that disk. Back up the disk together with the database.
2. Or add an object-storage adapter (for example Cloudflare R2 or Amazon S3). The architecture document already lists this as a future option. This needs a code change and new tests.

Verify first: in the Vercel project settings, confirm whether `IBVS_EVIDENCE_DIR` is set and where it points. Then run one upload in a staging copy and restart it to confirm the photo is still there.

F-02 · High · Health check reports a fixed migration name

Evidence: `apps/web/src/app/api/[...path]/route.ts` checks that `006_location_management.sql` is recorded and always returns that name. Production therefore reported "006" while the database was missing 007 to 009, which made it look healthy.

Risk: the health check gives false assurance about the database and cannot be used to confirm a deployment.

Fix: return the newest recorded migration from `schema_migrations`, and fail the check if any file in `db/migrations` is not recorded.

F-03 · High · No multi-factor sign-in for supervisors

Evidence: `apps/web/src/server/auth.ts` uses email and password only. `docs/SECURITY_THREAT_MODEL.md` lists administrator multi-factor sign-in as a deployment gate. Supervisors approve evidence and can change references.

Risk: a stolen or guessed supervisor password gives full control over approvals.

Fix: enable two-factor sign-in (Better Auth's two-factor plugin, using an authenticator app) for every administrator account before the pilot. Require it for approval and reference actions.

F-04 · High · Not tested on real phones

Evidence: `PROJECT_HANDOVER.md` records that real Android and iOS devices were not tested. All camera, GPS and offline tests run in a desktop browser with simulated inputs.

Risk: camera behaviour, GPS accuracy, storage limits, app suspension and offline recovery may fail on real phones.

Fix: run the checklist in `docs/M4_FIELD_DEVICE_CHECKLIST.md` on at least two Android phones and one iPhone, over HTTPS, with real workers' accounts on a test organization. Record results per item.

F-05 · High · Visits already queued with two photos will be rejected

Evidence: the rules now require three to six photos (`packages/domain/src/inspection.ts`). Drafts queued before the update still hold two photos, so they fail validation on every sync attempt. The photos stay on the phone, but the visit cannot be sent.

Risk: workers may believe their visits were sent when they were not, and may delete the app and lose the photos.

Fix: before the update reaches workers, ask them to send all queued visits. For anything still stuck, add a recovery step that lets a worker add an angle photo to an existing two-photo draft, and tell workers to keep the app installed until their queue is empty.

F-06 · Medium · Content Security Policy allows inline scripts

Evidence: the live policy includes `script-src 'self' 'unsafe-inline'` (`apps/web/next.config.ts`).

Risk: if any cross-site scripting bug is introduced later, inline scripts would run. Other headers are set correctly.

Fix: move to per-request nonces with Next.js middleware, and remove `'unsafe-inline'` from `script-src`.

F-07 · Medium · Production spatial queries are not verified

Evidence: the tests use an embedded database with a great-circle fallback. `docs/PROJECT_HANDOVER.md` says the PostGIS path and the remote PostGIS check have not been run.

Risk: nearby-face and GPS-distance checks may behave differently in production.

Fix: run `npm run test:postgis` against an isolated PostGIS database, and apply `db/spatial.sql` to staging before pilot.

F-08 · Medium · Database changes are a manual step, not part of deployment

Evidence: the runtime database account cannot create tables. Migrations must be run by hand with the admin account. Nothing in the deployment process does this, so the live database fell behind the code (see section 5).

Fix: add a migration step to the deployment, run with a separate admin secret, that stops the release when a migration is missing. Combine it with the fix for F-02.

F-09 · Medium · Arabic text has not been reviewed

Evidence: the worker messages added in this audit cycle (location, storage, online code, angle photos and brand choices) were written without a native-speaker review.

Fix: have a native speaker review every Arabic string in `apps/web/src/field/strings.ts` and `location-policy.ts` before workers receive them.

F-10 · Low · Health endpoint is public and reveals the database type

Evidence: `/api/health` answers without sign-in and returns the database type and migration name.

Fix: return only "ok" publicly; move the detailed status behind administrator sign-in.

F-11 · Low · Location-form browser test is timing-sensitive

Evidence: the "Add location" test passed and failed on different runs before the click was retried until the dialog opened. The app itself was not at fault.

Fix: keep the retry in place, and add an explicit wait for the workspace to be ready before the test starts.

F-12 · Low · Duplicated fetch logic in the location editor

Evidence: `apps/web/src/components/location-editor.tsx`, `DimensionRecord`, fetches the size history twice (once in an effect and once in the load helper).

Fix: have the effect call the load helper.

F-13 · Low · Some documents describe features as ready before they are verified

Evidence: `docs/M4_TEST_REPORT.md` and related files describe deployment gates that have not been run. The documents are honest about this in their text, but the summaries can be read as more complete than they are.

Fix: add a status line at the top of each release document that lists the gates still open.

F-14 · Low · Default production build fails on the audit machine

Evidence: `next build` (Turbopack) failed with a Windows child-process error while processing CSS. The same build succeeds with `next build --webpack`, and the failure happened with the CSS change removed too.

Fix: confirm on the build server (Vercel) that the default build passes. If it does not, switch to the webpack builder in the project configuration.

5. Incident note: database out of date

The live database had migrations 001 to 006 applied, and the code expected 007 to 009. The first attempt to apply them was run with the application's restricted database account and was refused. A later attempt, using a copy of the script, failed because one table already existed. A read-only check confirmed that the table was empty, that all nine migrations are now recorded, and that the media rule allows angle photos. The database is now up to date. The health check still showed 006 at the time of the check (see F-02).

6. Acceptance tests still required before pilot

#	Test	Owner	Status
1	Photo persistence after restart on the chosen host (F-01)	Owner and developer	Open
2	Full field visit with three photos on two Android phones and one iPhone (F-04)	Field tester	Open
3	Two-factor sign-in enabled for every administrator (F-03)	Owner	Open
4	Health check reports the newest migration (F-02)	Developer	Open
5	PostGIS suite on staging (F-07)	Developer	Open
6	Native-speaker review of Arabic text (F-09)	Arabic reviewer	Open
7	Queued two-photo drafts recovered before rollout (F-05)	Owner and field lead	Open

7. What passed

- Lint, typecheck, 124 unit and integration tests, and the production dependency audit (no high or critical vulnerabilities).
- Anonymous requests to inspections, reviews, locations, assignments and workers all return 401. Public sign-up returns 404.
- Responses include HSTS, `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff`, a referrer policy, and a Content Security Policy.
- The application's own mutating routes check the request origin. The sign-in route relies on the authentication library's origin checks, which were not tested separately. Database queries use parameters; the few interpolated identifiers come from fixed internal constants.
- Sign-in is rate-limited, sessions expire after 12 hours, and the production build refuses the embedded development database.

8. Recommended order of work

1. Resolve F-01 (storage location) and F-05 (queued drafts) before any worker uses the new version.
2. Complete the phone test (F-04) and two-factor sign-in (F-03).
3. Fix the health check (F-02) and add the migration step (F-08).
4. Close the medium and low items, and repeat the QA cycle.

Appendix A · Commands run

```
npm run lint
npm run typecheck
npx vitest run                 (124 tests, 20 files)
npm audit --omit=dev --audit-level=high
cd apps/web && npx next build --webpack
npm run test:browser           (Playwright, production build)
curl https://ooh-green.vercel.app/api/health
curl -o /dev/null -w "%{http_code}" https://ooh-green.vercel.app/api/inspections   (and other protected
endpoints)
```

Appendix B · Limits of this audit

This audit did not use real phones, did not test the Supabase project settings or backups, did not attempt to bypass any protection, and did not write to the production database. The read-only checks and the automated tests are evidence for the items above, not a substitute for the acceptance tests in section 6.